

Executive Summary

Purpose

This assessment evaluated AWS Identity and Access Management (IAM) configurations within a cloud lab environment. The review focused on user accounts, group assignments, multi-factor authentication (MFA), and IAM policies to identify security risks and validate adherence to least-privilege principles.

Assessment Scope

The following components were reviewed:

- IAM Users
- IAM Groups
- MFA Configuration
- IAM Policies
- Administrative Access
- Access Governance Controls

Overall Assessment

The environment demonstrates implementation of role-based access control (RBAC) and least-privilege principles through the use of custom groups and a restricted developer policy. However, several findings were identified, including missing MFA protections and the presence of an intentionally over-permissive policy used for security testing.

Environment Overview

Users Reviewed

User	Role
admin-user	Administrator
developer-user	Developer

security-analyst Security Operations

auditor-user Auditor

Groups Reviewed

Group	Purpose
Administrators	Administrative access
Developers	Development activities
SecurityTeam	Security monitoring
Auditors	Read-only auditing

Policies Reviewed

Policy	Type
Developer-S3-Read-Policy	Secure Custom Policy
Dangerous-FullAccess	Insecure Demonstration Policy

Security Findings

Finding 1 – Missing MFA Protection

Description

The following users do not have MFA enabled:

- developer-user
- auditor-user

Risk

Accounts protected only by passwords are more susceptible to:

- Credential stuffing
- Password spraying
- Phishing attacks
- Password reuse attacks

Severity

High

Recommendation

Require MFA enrollment for all IAM users.

Finding 2 – Excessive Permissions

Description

The policy:

Dangerous-FullAccess

contains:

```
{  
  "Effect": "Allow",  
  "Action": "*",  
  "Resource": "*" }  
}
```

Risk

This policy grants unrestricted access to all AWS services and resources.

An attacker obtaining these permissions could:

- Create administrator accounts
- Disable logging
- Modify security controls
- Exfiltrate sensitive data
- Delete infrastructure resources

Severity

Critical

Recommendation

Remove wildcard permissions and replace with role-specific least-privilege policies.

Finding 3 – Wildcard Resource Access

Description

The policy grants access to:

Resource = *

Risk

Users can access all supported AWS resources instead of only those required for their role.

Severity

Critical

Recommendation

Restrict permissions to specific AWS resources using ARN-based controls.

Positive Security Controls Identified

Control 1 – Role-Based Access Control

Users were assigned permissions through groups rather than directly to user accounts.

Benefit

- Easier administration
- Consistent permission management
- Reduced configuration errors

Control 2 – MFA Protection for Privileged Users

The following accounts have MFA enabled:

- admin-user
- security-analyst

Benefit

Provides additional protection against credential theft and account compromise.

Control 3 – Least Privilege Policy Design

The policy:

Developer-S3-Read-Policy

provides only:

s3:GetObject
s3:ListBucket

Benefit

Restricts access to only the permissions required for the developer role.

Risk Summary Table

Finding	Severity
Missing MFA (developer-user)	High
Missing MFA (auditor-user)	High
Dangerous-FullAccess Policy	Critical

Recommendations

Immediate Actions

- 1. Enable MFA for all IAM users.
- 2. Remove Dangerous-FullAccess from production environments.
- 3. Eliminate wildcard permissions whenever possible.
- 4. Restrict access using least-privilege principles.

Long-Term Actions

- 1. Conduct quarterly IAM access reviews.
- 2. Audit administrative permissions regularly.
- 3. Monitor IAM changes using CloudTrail.
- 4. Implement automated compliance checks.

Final Assessment

The AWS IAM environment demonstrates a strong foundational implementation of identity and access management concepts, including RBAC, MFA deployment, and least-privilege access controls. However, the existence of an over-permissive policy and incomplete MFA coverage introduce significant security risks that should be remediated before deployment to a production environment.

Overall Security Rating:

Category	Rating
Identity Management	Good
MFA Compliance	Needs Improvement
Least Privilege	Good

Access Governance	Good
Policy Security	Needs Improvement
Overall Posture	Moderate Risk